

# breach-response-toolkit

Incident Report v1.0.0

## Personal Data Breach Incident Report

Breach reference: B-2024-001

Generated (UTC): 2026-06-15T09:18:22.274239+00:00

Controller: Example Ltd

Assessed severity:

HIGH

DRAFT - CONFIDENTIAL

## Executive Summary

Timer status: EXPIRED

Elapsed: 17658.8 hours

Remaining: 0.0 hours

Notification deadline (UTC): 2024-06-12T14:30:00+00:00

Severity score: 55.0 / 100 (HIGH)

ICO notification: REQUIRED

Subject notification: NOT REQUIRED

### Breach description

Unauthorised access to customer financial records via SQL injection in the payment portal

### Root cause

Unpatched SQL injection vulnerability in payment portal - CVE-2024-XXXXX

## Article 33 Timer Detail

Detection (UTC): 2024-06-09T14:30:00+00:00

Elapsed hours: 17658.81

Remaining hours: 0.00

Window used: 100.0%

Alert level: EXPIRED

Expired: Yes

Deadline (UTC): 2024-06-12T14:30:00+00:00

## Severity Classification

Data type: 35.0

Scale: 20.0

Special category bonus: 0.0

Encryption reduction: 0.0

Total score: 55.0

### Reasoning

Severity assessed as HIGH (score 55.0/100) for breach B-2024-001. Primary data category: financial, affecting approximately 1,500 records. No Article 9 special category data identified in this assessment. Affected data was not encrypted, increasing exposure. ICO notification required; data subject notification not automatically indicated.

### Recommended actions

1. Preserve forensic evidence and maintain an append-only incident log.
2. Confirm DPO availability and review the 72-hour ICO notification timeline.
3. Prepare a draft ICO notification under Article 33(3) for legal review.
4. Assess whether affected individuals must be notified under Article 34.
5. Review encryption controls for data at rest (Art. 32(1)(a)) as a priority remediation.

## NIST CSF Mapping

Framework: NIST CSF v1.1

Functions impacted: PROTECT, DETECT

Failed controls: 4

Top failed control: PR.AC-4 - Access permissions and authorisations not managed per least privilege

### Failed controls

PR.AC-4: Access permissions and authorisations not managed per least privilege (Art. 32(1)(b) - ensuring ongoing confidentiality)

PR.DS-1: Data-at-rest not protected via encryption (Art. 32(1)(a) - pseudonymisation and encryption)

DE.CM-1: Network not monitored to detect potential cybersecurity events (Art. 32(1)(d) - testing security measures)

RS.CO-2: Severity escalation - control RS.CO-2 requires immediate attention (Art. 32 - security of processing)

### Recommended remediations

[IMMEDIATE] PR.AC-5: Implement network segmentation and access reviews

[IMMEDIATE] PR.DS-1: Encrypt sensitive personal data at rest using industry-standard algorithms

## Evidence Log Summary (Article 33(3))

Completeness: 100.0%

### (a) Nature of breach

Unauthorised access to customer financial records via SQL injection in the payment portal

Categories: bank account numbers, sort codes, full names, transaction references

### (b) DPO contact

Jane Smith | Data Protection Officer | dpo@organisation.com | 01234 567890

### (c) Likely consequences

- Financial fraud using exposed bank account numbers and sort codes
- Identity theft risk for 1,500 affected customers
- Potential regulatory action from the ICO

### (d) Measures taken

- Payment portal taken offline at 15:00 UTC on 9 June 2024
- Incident response team engaged; forensic investigation commenced
- Affected customers notified by email at 18:00 UTC on 9 June 2024
- SQL injection vulnerability patched; security scan in progress

## ICO Notification Draft

*DRAFT FOR REVIEW - must be reviewed by a qualified DPO or legal representative before submission to the ICO.*

UK GDPR - PERSONAL DATA BREACH NOTIFICATION  
Article 33 - Notification to Supervisory Authority  
DRAFT FOR REVIEW - Generated by breach-response-toolkit  
Generated: 2026-06-15T09:18:22.250245+00:00  
Breach Reference: B-2024-001

WARNING: This draft must be reviewed by a qualified DPO or legal representative before submission to the ICO.

Submit via: [ico.org.uk/report-a-breach](https://ico.org.uk/report-a-breach)

SECTION 1 - CONTROLLER DETAILS

Organisation name: Example Ltd  
ICO Registration number: ZA123456

Address: 1 Example Street, London, EC1A 1BB

SECTION 2 - CONTACT POINT [Article 33(3)(b)]

Name: Jane Smith  
Role: Data Protection Officer  
Email: [dpo@organisation.com](mailto:dpo@organisation.com)  
Telephone: 01234 567890

SECTION 3 - NATURE OF BREACH [Article 33(3)(a)]

Type of breach: CONFIDENTIALITY  
Description: Unauthorised access to customer financial records via SQL injection in the payment portal

Root cause: Unpatched SQL injection vulnerability in payment portal - CVE-2024-XXXX

Date/time breach detected (UTC): 2024-06-09T14:30:00+00:00

Date/time breach notified to ICO: 2026-06-15T09:18:22.250245+00:00

Time elapsed since detection: 17658.81 hours

Categories of personal data:

- bank account numbers
- sort codes
- full names
- transaction references

Approximate number of data subjects: 1500

Approximate number of records: 1500

Was the data encrypted? No

Does the breach involve special category data (Article 9)? No

SECTION 4 - LIKELY CONSEQUENCES [Article 33(3)(c)]

1. Financial fraud using exposed bank account numbers and sort codes

2. Identity theft risk for 1,500 affected customers

3. Potential regulatory action from the ICO

SECTION 5 - MEASURES TAKEN [Article 33(3)(d)]

1. Payment portal taken offline at 15:00 UTC on 9 June 2024

2. Incident response team engaged; forensic investigation commenced

3. Affected customers notified by email at 18:00 UTC on 9 June 2024

4. SQL injection vulnerability patched; security scan in progress

SECTION 6 - SEVERITY ASSESSMENT (INTERNAL)

Assessed severity: HIGH

ICO notification: REQUIRED

Subject notification: NOT REQUIRED

END OF DRAFT NOTIFICATION - Breach Ref: B-2024-001  
????????????????????????????????????????????????????????